

NonPro's Team — Môn học Kiểm thử phần mềm

TÀI LIỆU SRS

Đặc tả yêu cầu phần mềm — Green Juice Hub

Dự án: Green Juice Hub — Website thương mại điện tử nước ép & smoothie

Phiên bản: 1.0

Ngày biên soạn: 20/08/2026

Người biên soạn: Hiền Trần (Trưởng nhóm)

Nhóm: NonPro's Team — Hiền, Nhân, Huy, Vũ, Thiện

Phương pháp: Biên soạn từ khảo sát trực tiếp mã nguồn (reverse-engineered SRS)

Mục lục

(Mở bằng Microsoft Word: bấm chuột phải vào bảng dưới đây → Update Field, hoặc Ctrl+A rồi F9, để mục lục tự cập nhật số trang)

Mục lục	2
1. Giới thiệu	4
1.1 Mục đích	4
1.2 Phạm vi sản phẩm	4
1.3 Định nghĩa, từ viết tắt	4
1.4 Tài liệu tham khảo	5
2. Mô tả tổng quan	6
2.1 Bối cảnh sản phẩm	6
2.2 Nhóm chức năng chính	6
2.3 Đối tượng người dùng	6
2.4 Môi trường vận hành	7
2.5 Ràng buộc thiết kế & triển khai	7
2.6 Giả định và phụ thuộc	7
3. Yêu cầu chức năng	8
3.1 Xác thực & Quản lý tài khoản	8
3.2 Sản phẩm & Tìm kiếm	10
3.3 Giỏ hàng	11
3.4 Khuyến mãi	11
3.5 Đặt hàng, Thanh toán & Vận chuyển	11
3.6 Đánh giá sản phẩm	14
3.7 Liên hệ, Banner & Chính sách	15
3.8 Tư vấn sản phẩm bằng AI	15
3.9 Quản trị hệ thống (Admin/Staff)	16
4. Yêu cầu phi chức năng	19
4.1 Tính khả dụng (Usability)	19
4.2 Bảo mật (Security)	19
4.3 Hiệu năng (Performance)	19
4.4 Độ tin cậy (Reliability)	20
4.5 Khả năng tương thích (Compatibility)	20
4.6 Khả năng bảo trì (Maintainability)	20
4.7 Yêu cầu pháp lý / Dữ liệu	20
5. Ma trận phân quyền theo vai trò	21
6. Phụ lục	22
Phụ lục A — Danh sách API đầy đủ theo controller	22
Phụ lục B — Danh mục 23 bảng dữ liệu	23
Phụ lục C — Ghi chú về phương pháp biên soạn	23

1. Giới thiệu

1.1 Mục đích

Tài liệu này đặc tả các yêu cầu chức năng và phi chức năng của hệ thống Green Juice Hub — website thương mại điện tử bán nước ép, smoothie, granola và sữa chua Hy Lạp. Tài liệu được biên soạn bằng cách khảo sát trực tiếp mã nguồn thực tế của dự án (frontend, backend, cơ sở dữ liệu) do dự án được xây dựng trước, không có tài liệu yêu cầu gốc. Mục đích chính là tạo ra một đường cơ sở (baseline) yêu cầu rõ ràng, thống nhất trong nhóm, làm căn cứ để nhóm thiết kế test case, thực hiện kiểm thử và đánh giá kết quả trong môn học Kiểm thử phần mềm.

1.2 Phạm vi sản phẩm

Green Juice Hub là một ứng dụng web full-stack gồm 3 thành phần: giao diện người dùng (frontend React), máy chủ ứng dụng (backend Spring Boot) và cơ sở dữ liệu quan hệ (MySQL). Hệ thống phục vụ 3 nhóm người dùng: khách hàng mua sắm trực tuyến (Customer), nhân viên vận hành (Staff) và quản trị viên (Admin). Phạm vi chức năng bao gồm: đăng ký/đăng nhập đa phương thức, duyệt và tìm kiếm sản phẩm, giỏ hàng, đặt hàng, thanh toán (COD và các hình thức online), khuyến mãi, đánh giá sản phẩm, tư vấn sản phẩm bằng AI, liên hệ, và một hệ thống quản trị (Admin Dashboard) đầy đủ cho vận hành cửa hàng.

Tài liệu này KHÔNG bao gồm: quy trình vận hành nội bộ ngoài phạm vi phần mềm (ví dụ đóng gói, giao nhận thực tế), và không đặc tả chi tiết giao diện (UI mock-up) — phần mô tả kiến trúc và thiết kế kỹ thuật chi tiết được trình bày trong "Tài liệu mô tả hệ thống" đi kèm.

1.3 Định nghĩa, từ viết tắt

Thuật ngữ	Giải thích
SRS	Software Requirements Specification — Tài liệu đặc tả yêu cầu phần mềm
FR / NFR	Functional Requirement / Non-Functional Requirement — Yêu cầu chức năng / phi chức năng
Customer	Khách hàng — vai trò user.role = CUSTOMER, mua sắm trên site
Staff	Nhân viên — vai trò user.role = STAFF, hỗ trợ vận hành (quyền hạn chế hơn Admin)
Admin	Quản trị viên — vai trò user.role = ADMIN, toàn quyền quản trị hệ thống
JWT	JSON Web Token — cơ chế token dùng để xác thực phiên đăng nhập (access token + refresh token)
OTP	One-Time Password — mã xác thực dùng một lần gửi qua SMS tới số điện thoại
GHN	Giao Hàng Nhanh — đơn vị vận chuyển tích hợp để tính phí ship và tạo vận đơn
VNPay / Momo / SePay	Các cổng/đơn vị hỗ trợ thanh toán trực tuyến được tích hợp trong hệ thống
IPN	Instant Payment Notification — cơ chế cổng thanh toán gọi ngược về server để xác nhận giao dịch
Webhook	Cơ chế bên thứ ba (SePay) gọi vào hệ thống để báo có giao dịch chuyển khoản mới
Variant (biến thể)	Tổ hợp cụ thể của 1 sản phẩm theo hương vị (flavor) và kích cỡ (size), có giá/tồn kho riêng

Thuật ngữ	Giải thích
Soft delete (xoá mềm)	Đánh dấu <code>is_deleted = true</code> thay vì xoá vật lý khỏi cơ sở dữ liệu
Mã đơn hàng	Định dạng "GJH-XXXXXXX", sinh tự động, duy nhất cho mỗi đơn hàng

1.4 Tài liệu tham khảo

- Mã nguồn dự án Green Juice Hub — repository "green-juice-hub" (nhánh main), khảo sát trực tiếp tại `H:\Project\KTPM` trên máy của trưởng nhóm.
- README.md gốc của dự án (mô tả tính năng, tech stack, cấu trúc thư mục — lưu ý README ghi 22 bảng dữ liệu, đã lỗi thời so với schema.sql thực tế hiện có 23 bảng).
- Tài liệu "Kế hoạch kiểm thử — Green Juice Hub" (lưu trong Claude Project "Uni - Kiểm thử phần mềm") — kế hoạch phân công, timeline, phát hiện bảo mật ban đầu của nhóm.
- Tài liệu "Mô tả hệ thống — Green Juice Hub" (tài liệu song hành với SRS này) — mô tả chi tiết kiến trúc, công nghệ, luồng nghiệp vụ kỹ thuật.
- Tài liệu môn học Kiểm thử phần mềm (Chương I–VII) — làm khung tham chiếu cho cấu trúc yêu cầu phi chức năng và kế hoạch kiểm thử của nhóm.

2. Mô tả tổng quan

2.1 Bối cảnh sản phẩm

Green Juice Hub là sản phẩm độc lập (không phải bản nâng cấp/thay thế hệ thống cũ). Hệ thống được một thành viên trong nhóm (Vũ) tự xây dựng hoàn chỉnh cả frontend, backend và cơ sở dữ liệu trước khi nhóm bắt đầu môn học Kiểm thử phần mềm, dựa trên ý tưởng cá nhân, không theo một tài liệu yêu cầu được duyệt trước. Vì vậy tài liệu SRS này được xây dựng theo hướng "hồi tố" (reverse-engineered) — mô tả lại đúng hành vi mà hệ thống thực tế đang triển khai, kết hợp ghi chú các điểm cần làm rõ/cần kiểm thử thêm khi phát hiện sự mơ hồ hoặc chưa nhất quán trong mã nguồn.

2.2 Nhóm chức năng chính

- Xác thực & tài khoản: đăng ký/đăng nhập bằng OTP qua SMS, mật khẩu, hoặc Google OAuth2; quản lý hồ sơ và địa chỉ giao hàng.
- Danh mục sản phẩm: tìm kiếm, lọc đa tiêu chí, sắp xếp, xem chi tiết sản phẩm với nhiều biến thể (hương vị × kích cỡ).
- Giỏ hàng & Đặt hàng: thêm/sửa/xoá giỏ hàng, đặt hàng từ giỏ hoặc mua ngay, áp dụng khuyến mãi, tính phí vận chuyển theo địa chỉ thực (tích hợp GHN).
- Thanh toán: COD, VNPAY (cổng thanh toán thật), MoMo và Chuyển khoản ngân hàng (chuyển khoản thủ công, xác nhận tự động qua webhook SePay).
- Khuyến mãi: mã giảm giá công khai hoặc cá nhân hoá, kiểm tra điều kiện áp dụng theo thời gian thực.
- Đánh giá sản phẩm: khách hàng đã nhận hàng có thể đánh giá kèm sao và bình luận; cửa hàng có thể phản hồi.
- Tư vấn sản phẩm bằng AI: chatbot dựa trên Google Gemini, gợi ý sản phẩm phù hợp theo nhu cầu mô tả bằng ngôn ngữ tự nhiên.
- Nội dung hỗ trợ: banner trang chủ, chính sách (vận chuyển/đổi trả/bảo hành/điều khoản), form liên hệ.
- Quản trị (Admin/Staff): quản lý sản phẩm, đơn hàng, khuyến mãi, người dùng, đánh giá, liên hệ, banner, chính sách, nhãn sản phẩm, và trang tổng quan (dashboard) doanh thu.

2.3 Đối tượng người dùng

Vai trò	Mô tả	Đặc điểm / Quyền hạn chính
Khách (Guest)	Người dùng chưa đăng nhập	Xem sản phẩm, banner, chính sách; gửi liên hệ; dùng AI tư vấn; không thể mua hàng
Customer	Khách hàng đã đăng ký, vai trò mặc định khi tạo tài khoản mới	Toàn bộ chức năng mua sắm: giỏ hàng, đặt hàng, thanh toán, đánh giá, quản lý địa chỉ/hồ sơ
Staff	Nhân viên vận hành	Xem/xử lý đơn hàng, kiểm duyệt đánh giá, xử lý liên hệ, xem dashboard, xem (không sửa) danh mục sản phẩm — không có quyền với khuyến mãi, người dùng, banner, chính sách, nhãn sản phẩm
Admin	Quản trị viên cấp cao nhất	Toàn quyền trên mọi module quản trị, bao gồm cả các module Staff không được phép (khuyến mãi, người dùng, banner, chính sách)

Ma trận phân quyền chi tiết theo từng nhóm chức năng được trình bày đầy đủ ở Mục 5.

2.4 Môi trường vận hành

Hệ thống triển khai theo mô hình client-server 3 lớp: Frontend React (Vercel), Backend Spring Boot (Railway), Cơ sở dữ liệu MySQL + Redis (cache/session). Chi tiết công nghệ, kiến trúc và sơ đồ triển khai được trình bày đầy đủ trong Tài liệu mô tả hệ thống. Yêu cầu môi trường phát triển tối thiểu: Node.js ≥ 18 , JDK 21, MySQL ≥ 8.0 , Redis, Maven ≥ 3.8 .

2.5 Ràng buộc thiết kế & triển khai

- Xác thực toàn hệ thống dùng JWT stateless (không lưu session phía server ngoài Redis dùng cho blacklist/rate-limit) — mọi request cần token đều đi qua bộ lọc JwtAuthFilter.
- Khu vực giao hàng hiện tại chỉ hỗ trợ TP. Hồ Chí Minh (giới hạn cấu hình ở tầng frontend, danh sách DELIVERY_PROVINCES) — đây là ràng buộc kinh doanh hiện hành, không phải giới hạn kỹ thuật của GHN.
- Backend không tích hợp công cụ sinh tài liệu API tự động (không có springdoc/Swagger trong pom.xml) — nhóm cần tự xây dựng Postman collection để phục vụ kiểm thử API.
- Một số phương thức thanh toán (MoMo, Chuyển khoản ngân hàng) không gọi cổng thanh toán thật mà mô phỏng bằng chuyển khoản thủ công + webhook xác nhận — cần được hiểu đúng khi thiết kế test case, tránh nhầm là lỗi tích hợp.

2.6 Giả định và phụ thuộc

- Giả định các dịch vụ bên thứ ba (Google OAuth/reCAPTCHA, VNPay sandbox, GHN, Cloudinary, Gemini API, SePay) luôn khả dụng và đúng hợp đồng API tại thời điểm kiểm thử; nhóm cần chuẩn bị tài khoản/khoá API test riêng, không dùng chung khoá thật đang bị rò rỉ (xem ghi chú bảo mật ở Mục 4.2).
- Phụ thuộc Redis đang chạy để các chức năng OTP lock, chống brute-force đăng nhập, và thu hồi token (blacklist) hoạt động đúng; nếu Redis không khả dụng, các chức năng này có thể bị ảnh hưởng — cần kiểm thử riêng kịch bản Redis gián đoạn nếu có thời gian.
- Backend triển khai trên Railway có thể "ngủ" (cold start) sau thời gian không có truy cập — lần gọi API đầu tiên có thể chậm bất thường; đây là đặc điểm hạ tầng, không phải lỗi chức năng.

3. Yêu cầu chức năng

Các yêu cầu chức năng được nhóm theo module nghiệp vụ, bám sát theo controller/service thực tế trong mã nguồn để thuận tiện truy vết (traceability) khi thiết kế test case. Mỗi yêu cầu gồm: mã định danh, tên, quy tắc nghiệp vụ suy ra từ mã nguồn, và (các) API liên quan.

3.1 Xác thực & Quản lý tài khoản

FR-AUTH-01 Kiểm tra tài khoản theo số điện thoại

Tác nhân: Khách (chưa đăng nhập)

Trước khi cho nhập mật khẩu, hệ thống kiểm tra số điện thoại đã tồn tại tài khoản và đã có mật khẩu hay chưa, làm căn cứ điều hướng sang luồng OTP hoặc luồng chọn phương thức đăng nhập.

Quy tắc nghiệp vụ / Điều kiện:

- Số điện thoại là định danh chính để tra cứu tài khoản.
- Kết quả trả về gồm 2 cờ: isNewUser (tài khoản chưa tồn tại) và hasPassword (đã từng đặt mật khẩu).
- Nếu isNewUser = true hoặc hasPassword = false → bắt buộc phải qua bước gửi OTP (FR-AUTH-02); nếu hasPassword = true → cho phép chọn giữa đăng nhập bằng OTP hoặc bằng mật khẩu.

API liên quan: POST /api/auth/check-account

FR-AUTH-02 Đăng ký / đăng nhập bằng mã OTP qua SMS

Tác nhân: Khách / Customer

Xác thực bằng mã OTP 6 chữ số gửi tới số điện thoại, dùng chung cho 3 kịch bản: đăng ký tài khoản mới (REGISTER), đăng nhập không cần mật khẩu (LOGIN), và lấy lại mật khẩu (RESET_PASSWORD).

Quy tắc nghiệp vụ / Điều kiện:

- Gửi OTP: tối đa 10 lần gửi/ngày cho mỗi số điện thoại; mã OTP hết hạn sau 5 phút.
- Xác thực OTP: cho phép tối đa 3 lần nhập sai trước khi khoá xác thực của số điện thoại đó trong 15 phút.
- Xác thực OTP thành công trả về một "tempToken" thời hạn ngắn — dùng cho bước kế tiếp (đăng nhập thẳng / đặt mật khẩu / đặt lại mật khẩu), không dùng trực tiếp như access token.
- Nếu là số điện thoại hoàn toàn mới, hệ thống tự động tạo tài khoản với vai trò CUSTOMER ngay khi xác thực OTP đăng ký thành công.
- Người dùng có thể đăng nhập thẳng bằng tempToken (bỏ qua bước đặt mật khẩu) nếu muốn.

API liên quan: POST /api/auth/send-otp | POST /api/auth/verify-otp | POST /api/auth/login-with-otp

FR-AUTH-03 Đăng nhập bằng mật khẩu

Tác nhân: Customer / Staff / Admin

Đăng nhập bằng số điện thoại, email hoặc username kèm mật khẩu. Dùng chung một endpoint cho cả 3 vai trò — hệ thống không có trang đăng nhập quản trị riêng biệt.

Quy tắc nghiệp vụ / Điều kiện:

- Định danh đăng nhập (identifier) chấp nhận số điện thoại, email hoặc username.
- Hệ thống đếm số lần đăng nhập sai liên tiếp; sau khi vượt ngưỡng cho phép, trả lỗi HTTP 403 và bắt buộc xác minh Google reCAPTCHA v2 trong (các) lần thử tiếp theo cho đến khi đăng nhập đúng.

- Đăng nhập thành công trả về accessToken, refreshToken và role; FE điều hướng CUSTOMER → trang chủ, STAFF/ADMIN → khu vực quản trị (/admin).

API liên quan: POST /api/auth/login

FR-AUTH-04 Đăng nhập bằng Google (OAuth2)

Cho phép đăng nhập/đăng ký bằng tài khoản Google.

Quy tắc nghiệp vụ / Điều kiện:

- Backend xác thực idToken do Google cấp phía client.
- Nếu tài khoản Google chưa liên kết với người dùng nào trong hệ thống, tự động tạo tài khoản mới (vai trò CUSTOMER) và liên kết qua bảng social_accounts (provider = GOOGLE).

API liên quan: POST /api/auth/google

FR-AUTH-05 Thiết lập / đặt lại mật khẩu bằng OTP

Sau khi xác thực OTP (REGISTER hoặc RESET_PASSWORD) và có tempToken hợp lệ, người dùng đặt mật khẩu mới cho tài khoản.

Quy tắc nghiệp vụ / Điều kiện:

- Mật khẩu tối thiểu 8 ký tự (kiểm tra ở giao diện); cần kiểm thử xác nhận backend cũng validate độc lập, không chỉ dựa vào ràng buộc phía frontend.
- Trường xác nhận mật khẩu (nhập lại) phải khớp với mật khẩu mới trước khi gửi yêu cầu.
- Đặt mật khẩu thành công sẽ đăng nhập luôn cho người dùng (trả về access/refresh token), không yêu cầu đăng nhập lại thủ công.

API liên quan: POST /api/auth/set-password | POST /api/auth/reset-password

FR-AUTH-06 Đổi mật khẩu khi đã đăng nhập

Quy tắc nghiệp vụ / Điều kiện:

- Yêu cầu nhập đúng mật khẩu hiện tại trước khi cho phép đổi sang mật khẩu mới.
- Ghi nhận từ khảo sát mã nguồn: hệ thống hiện có 2 API cùng chức năng đổi mật khẩu (một ở AuthController, một ở UserController); giao diện Cài đặt/Hồ sơ hiện gọi API của UserController. Cần kiểm thử xác nhận cả hai có hành vi nhất quán, tránh trùng lặp logic gây khó bảo trì hoặc sai lệch validate giữa 2 nơi.

API liên quan: PUT /api/users/me/password | POST /api/auth/change-password

FR-AUTH-07 Làm mới access token / Đăng xuất

Quy tắc nghiệp vụ / Điều kiện:

- "Làm mới" dùng refreshToken (qua header Authorization: Bearer) để cấp access token và refresh token mới; access token có hiệu lực 1 giờ, refresh token có hiệu lực 7 ngày.
- "Đăng xuất" đưa access token hiện tại vào danh sách thu hồi (blacklist) trên Redis; token đã đăng xuất phải bị từ chối ở các request kể tiếp dù chưa hết hạn theo thời gian.
- Frontend tự động gọi làm mới token khi gặp lỗi 401 (nếu còn refreshToken hợp lệ), có cơ chế xếp hàng các request khác đang chờ trong lúc làm mới để tránh gọi trùng lặp.

API liên quan: POST /api/auth/refresh | POST /api/auth/logout

FR-AUTH-08 Xem / cập nhật hồ sơ cá nhân

Quy tắc nghiệp vụ / Điều kiện:

- Cho phép xem và cập nhật họ tên, email, username, ảnh đại diện.

API liên quan: GET /api/users/me | PUT /api/users/me

FR-AUTH-09 Quản lý địa chỉ giao hàng

Tác nhân: Customer

Quy tắc nghiệp vụ / Điều kiện:

- Mỗi người dùng được lưu tối đa 5 địa chỉ.
- Tại một thời điểm chỉ có đúng 1 địa chỉ được đánh dấu mặc định; đặt một địa chỉ khác làm mặc định sẽ tự động bỏ mặc định địa chỉ trước đó.
- Địa chỉ lưu kèm mã quận/huyện và mã phường/xã theo chuẩn GHN để phục vụ tính phí vận chuyển thời gian thực; địa chỉ được tạo trước khi hệ thống tích hợp GHN có thể thiếu 2 trường này (xem cơ chế dự phòng ở FR-ORD-01).
- Khu vực được phép chọn khi tạo địa chỉ hiện chỉ giới hạn ở TP. Hồ Chí Minh — đây là giới hạn kinh doanh hiện tại, không phải lỗi phần mềm.

API liên quan: GET/POST /api/users/me/addresses | GET/PUT/DELETE /api/users/me/addresses/{id} | PATCH /api/users/me/addresses/{id}/default

3.2 Sản phẩm & Tìm kiếm

FR-PROD-01 Xem danh sách / tìm kiếm sản phẩm

Tác nhân: Khách, Customer

Quy tắc nghiệp vụ / Điều kiện:

- Hỗ trợ phân trang (mặc định 12 sản phẩm/trang), tìm theo từ khoá tên sản phẩm.
- Lọc theo: danh mục, hương vị (chọn nhiều), kích cỡ (chọn nhiều), nhãn/tag (chọn nhiều), khoảng giá (từ – đến), đánh giá tối thiểu, còn hàng, đang giảm giá.
- 6 kiểu sắp xếp: mới nhất, bán chạy, giá tăng dần, giá giảm dần, đánh giá cao, đánh giá thấp/giảm nhiều nhất.
- Giao diện debounce 300ms trước khi gọi API khi người dùng đổi bộ lọc; lưu lại trạng thái lọc và vị trí cuộn trong phiên duyệt web để khôi phục khi quay lại danh sách từ trang chi tiết sản phẩm.

API liên quan: GET /api/products

FR-PROD-02 Xem chi tiết sản phẩm

Quy tắc nghiệp vụ / Điều kiện:

- Truy cập theo slug (định danh dạng chữ, thân thiện SEO), không phải theo id số.
- Hiển thị đầy đủ các biến thể (tổ hợp hương vị × kích cỡ) với giá gốc/giá sale/% giảm/tồn kho riêng từng biến thể, thư viện ảnh, mô tả định dạng rich text, các nhãn gắn kèm (Bestseller/Organic/New/Sale...) và danh sách sản phẩm liên quan.
- Sản phẩm được coi là hết hàng khi toàn bộ biến thể có tồn kho bằng 0.

API liên quan: GET /api/products/{slug}

FR-PROD-03 Lấy dữ liệu danh mục phục vụ lọc/hiển thị

Quy tắc nghiệp vụ / Điều kiện:

- Cung cấp danh sách danh mục, hương vị, kích cỡ, nhãn đang hoạt động để dựng bộ lọc và các form liên quan.

API liên quan: GET /api/products/categories | GET /api/products/flavors | GET /api/products/sizes | GET /api/products/tags

FR-PROD-04 "Deal sốc" theo danh mục giảm giá**Quy tắc nghiệp vụ / Điều kiện:**

- Liệt kê các danh mục hiện đang có sản phẩm khuyến mãi/giảm giá để làm nổi bật ở đầu trang danh sách sản phẩm.

API liên quan: GET /api/products/deal-categories

3.3 Giỏ hàng**FR-CART-01 Xem, thêm, cập nhật, xoá sản phẩm trong giỏ hàng**

Tác nhân: Customer

Quy tắc nghiệp vụ / Điều kiện:

- Mỗi người dùng có duy nhất một giỏ hàng.
- Thêm một sản phẩm (theo biến thể) đã có sẵn trong giỏ sẽ cộng dồn số lượng thay vì tạo dòng mới.
- Toàn bộ module giỏ hàng yêu cầu đã đăng nhập với vai trò CUSTOMER — hệ thống không hỗ trợ giỏ hàng cho khách vắng lai (guest cart).
- Giỏ hàng (lưu cục bộ ở FE) được làm mới khi đăng xuất, tránh lẫn dữ liệu giữa 2 tài khoản dùng chung trình duyệt.

API liên quan: GET /api/cart | POST /api/cart/items | PUT /api/cart/items/{cartItemId} | DELETE /api/cart/items/{cartItemId} | DELETE /api/cart

3.4 Khuyến mãi**FR-PROMO-01 Xem mã khuyến mãi khả dụng**

Tác nhân: Customer

Quy tắc nghiệp vụ / Điều kiện:

- Áp dụng cho 2 ngữ cảnh: giỏ hàng (theo danh sách cartItemId đã chọn) hoặc mua ngay (theo biến thể + số lượng).
- Mỗi mã trả về kèm cờ "đủ điều kiện" (isEligible) và lý do nếu chưa đủ điều kiện (ví dụ chưa đạt giá trị đơn hàng tối thiểu), giúp khách hàng biết cần mua thêm bao nhiêu để được áp dụng.
- Khuyến mãi có 2 phạm vi: PUBLIC (áp dụng chung cho mọi khách hàng) và PERSONAL (chỉ áp dụng cho 1 khách hàng cụ thể, do Admin tạo riêng — xem FR-ADMIN-USER-02).

API liên quan: POST /api/promos/available

FR-PROMO-02 Áp dụng mã khuyến mãi khi đặt hàng**Quy tắc nghiệp vụ / Điều kiện:**

- Loại giảm giá: PERCENT (giảm theo phần trăm) hoặc FIXED (giảm số tiền cố định).
- Toàn bộ điều kiện (giá trị đơn tối thiểu, giới hạn tổng lượt dùng toàn hệ thống, giới hạn lượt dùng trên mỗi người dùng, còn hiệu lực theo thời gian, đúng phạm vi PUBLIC/PERSONAL) phải được kiểm tra lại tại thời điểm đặt hàng, không chỉ dựa vào kết quả xem trước ở FR-PROMO-01 — cần thiết kế test case cho tình huống mã hết lượt/hết hạn đúng lúc giữa hai bước.

API liên quan: POST /api/orders/apply-promo (xem trước) | áp dụng thực tế khi POST /api/orders hoặc POST /api/orders/buy-now

3.5 Đặt hàng, Thanh toán & Vận chuyển

FR-ORD-01 Tính phí vận chuyển**Quy tắc nghiệp vụ / Điều kiện:**

- Tính theo địa chỉ giao hàng (thông qua mã quận/huyện, phường/xã theo chuẩn GHN đã lưu ở địa chỉ) và tổng khối lượng đơn hàng (khối lượng từng biến thể × số lượng; mặc định 500g nếu biến thể chưa khai báo khối lượng).
- Nếu địa chỉ chưa có dữ liệu GHN (địa chỉ được tạo trước khi tích hợp GHN) → áp dụng mức phí cố định 30.000đ thay vì gọi dịch vụ GHN.

API liên quan: POST /api/orders/shipping-fee | GET /api/shipping/provinces|districts|wards

FR-ORD-02 Đặt hàng từ giỏ hàng

Tác nhân: Customer

Quy tắc nghiệp vụ / Điều kiện:

- Chỉ đặt các dòng sản phẩm đã được chọn trong giỏ hàng, không bắt buộc đặt toàn bộ giỏ.
- Bắt buộc chọn một địa chỉ giao hàng đã lưu (hoặc thêm nhanh một địa chỉ mới ngay tại bước thanh toán).
- Chọn một trong 4 phương thức thanh toán: COD, VNPay, MoMo, Chuyển khoản ngân hàng (xem chi tiết ở FR-PAY-01 đến FR-PAY-03).
- Có thể nhập ghi chú đơn hàng và áp dụng mã khuyến mãi (không bắt buộc).
- Mã đơn hàng được sinh tự động theo định dạng "GJH-XXXXXXX", duy nhất.
- Trạng thái khởi tạo: trạng thái đơn = PENDING, trạng thái thanh toán = PENDING.
- Đơn hàng thanh toán online có thời hạn thanh toán; quá hạn sẽ bị tự động huỷ (xem FR-ORD-08).

API liên quan: POST /api/orders

FR-ORD-03 Mua ngay (Buy Now)

Tương tự FR-ORD-02 nhưng không đi qua giỏ hàng — chỉ một biến thể và số lượng được chọn trực tiếp từ trang chi tiết sản phẩm.

API liên quan: POST /api/orders/buy-now

FR-ORD-04 Xem danh sách đơn hàng của tôi**Quy tắc nghiệp vụ / Điều kiện:**

- Hỗ trợ phân trang, lọc theo trạng thái, kèm số lượng đơn theo từng trạng thái để hiển thị badge trên giao diện.

API liên quan: GET /api/orders | GET /api/orders/status-counts

FR-ORD-05 Xem chi tiết đơn hàng

API liên quan: GET /api/orders/{orderId}

FR-ORD-06 Huỷ đơn hàng**Quy tắc nghiệp vụ / Điều kiện:**

- Chỉ được phép huỷ khi đơn đang ở trạng thái PENDING.
- Có thể kèm theo lý do huỷ; hệ thống ghi nhận người huỷ là khách hàng (CUSTOMER).

API liên quan: PATCH /api/orders/{orderId}/cancel

FR-ORD-07 Xác nhận đã nhận hàng

Quy tắc nghiệp vụ / Điều kiện:

- Chỉ thực hiện được khi đơn đang ở trạng thái SHIPPING (đang giao).
- Xác nhận thành công chuyển đơn sang DELIVERED; với đơn thanh toán COD, trạng thái thanh toán cũng chuyển sang PAID ngay tại bước này.

API liên quan: PATCH /api/orders/{orderId}/confirm-delivered

FR-ORD-08 Tự động huỷ đơn quá hạn thanh toán

Tác nhân: Hệ thống (tác vụ nền, chạy mỗi 5 phút)

Quy tắc nghiệp vụ / Điều kiện:

- Quét các đơn thanh toán online còn ở trạng thái PENDING đã quá thời hạn thanh toán → tự động chuyển sang CANCELLED, ghi nhận người huỷ là hệ thống (SYSTEM), nhằm giải phóng tồn kho và lượt dùng khuyến mãi đã tạm giữ.

FR-ORD-09 Tự động cập nhật trạng thái giao hàng

Tác nhân: Hệ thống (tác vụ nền, chạy 2 giờ sáng hằng ngày)

Quy tắc nghiệp vụ / Điều kiện:

- Quét và tự động cập nhật trạng thái vận chuyển của các đơn phù hợp theo lịch cố định.
- Do đây là tác vụ nền chạy ngầm, khó quan sát trực tiếp qua giao diện — nhóm nên ưu tiên kiểm thử ở mức unit/integration (gọi trực tiếp job hoặc chỉnh thời gian hệ thống) thay vì chỉ kiểm thử qua UI.

FR-PAY-01 Thanh toán khi nhận hàng (COD)**Quy tắc nghiệp vụ / Điều kiện:**

- Không yêu cầu thao tác thanh toán online.
- Sau khi đặt hàng, hiển thị màn hình xác nhận thành công với bộ đếm ngược 5 giây, sau đó tự động chuyển sang trang chi tiết đơn hàng.

FR-PAY-02 Thanh toán qua VNPay**Quy tắc nghiệp vụ / Điều kiện:**

- Sau khi đặt hàng, hệ thống tạo URL thanh toán và điều hướng người dùng sang cổng VNPay (môi trường sandbox).
- Backend ký các tham số giao dịch bằng HMAC-SHA512 với khoá bí mật cấu hình riêng theo môi trường (không hard-code trong mã nguồn).
- VNPay gọi lại qua 2 kênh: IPN (server-to-server, xác nhận chính thức kết quả giao dịch, không cần đăng nhập) và Return (trình duyệt người dùng được đưa về ứng dụng); do frontend (Vercel) và backend (Railway) khác domain, backend không redirect thẳng mà trả dữ liệu để trang kết quả trên frontend tự gọi lại xác minh.
- Chữ ký giao dịch (SecureHash) phải được xác minh khớp trước khi cập nhật trạng thái thanh toán, nhằm chống giả mạo kết quả giao dịch.

API liên quan: POST /api/payment/vnpay/create-url | GET /api/payment/vnpay/ipn | GET /api/payment/vnpay/return

FR-PAY-03 Thanh toán qua MoMo / Chuyển khoản ngân hàng

Ghi chú quan trọng: cả hai phương thức MOMO và BANK_TRANSFER trong hệ thống hiện tại đều là hình thức chuyển khoản ngân hàng thủ công — KHÔNG gọi API cổng thanh toán MoMo thật. Giao diện hiển thị khác nhau theo thương hiệu (MoMo/ngân hàng) nhưng dùng chung một cơ chế xác nhận.

Quy tắc nghiệp vụ / Điều kiện:

- Hiển thị mã QR VietQR động (số tiền + nội dung chuyển khoản = mã đơn hàng) và thông tin chuyển khoản thủ công (tên ngân hàng, số tài khoản, chủ tài khoản) để người dùng tự thực hiện chuyển khoản bằng ứng dụng ngân hàng hoặc ứng dụng MoMo.
- Giao diện tự động kiểm tra trạng thái đơn hàng mỗi 3 giây để phát hiện thời điểm trạng thái thanh toán chuyển sang PAID.
- Việc xác nhận PAID được thực hiện tự động qua webhook SePay (FR-PAY-04) khi hệ thống nhận được giao dịch chuyển khoản thực tế khớp nội dung — không có bước xác nhận thủ công từ phía Admin trong luồng thông thường.
- Đây là điểm quan trọng cần thể hiện rõ trong test case: chọn "MoMo" sẽ KHÔNG mở ứng dụng MoMo hay chuyển sang cổng thanh toán — mà hiển thị màn hình chuyển khoản ngân hàng. Đây là đúng thiết kế hiện tại của hệ thống, không phải lỗi, nhưng dễ gây hiểu nhầm nếu kiểm thử chỉ dựa theo tên gọi chức năng.

API liên quan: Dùng chung POST /api/orders với paymentMethod = MOMO hoặc BANK_TRANSFER; xác nhận qua webhook ở FR-PAY-04

FR-PAY-04 Xác nhận thanh toán chuyển khoản qua webhook SePay

Tác nhân: Hệ thống bên thứ ba (SePay) gọi vào

Quy tắc nghiệp vụ / Điều kiện:

- Endpoint xác thực bằng header Authorization dạng "apikey {khóa cấu hình riêng theo môi trường}", không dùng cơ chế JWT như các API còn lại.
- Đối chiếu nội dung chuyển khoản để trích xuất mã đơn hàng (theo định dạng GJH-XXXXXXX) và xác minh số tiền chuyển khoản khớp với tổng tiền đơn hàng trước khi đánh dấu PAID.
- Luôn phản hồi HTTP 200 cho SePay (kể cả khi không tìm thấy đơn khớp) để tránh bị gọi lại liên tục — đồng nghĩa các lỗi xử lý nội bộ sẽ không được tự động thử lại, cần theo dõi qua log riêng.

API liên quan: POST /api/webhooks/sepay

3.6 Đánh giá sản phẩm

FR-REVIEW-01 Viết đánh giá sản phẩm

Tác nhân: Customer

Quy tắc nghiệp vụ / Điều kiện:

- Chỉ khách hàng có đơn hàng chứa sản phẩm đó và đơn đã ở trạng thái DELIVERED mới được phép đánh giá.
- Đánh giá gồm số sao (1–5) và nội dung nhận xét, có thể kèm hình ảnh.
- Đánh giá hợp lệ được tự động duyệt (hiển thị công khai ngay); Admin/Staff có thể ẩn lại sau đó nếu cần (xem FR-ADMIN-REVIEW-01).

API liên quan: POST /api/reviews | GET /api/reviews/check

FR-REVIEW-02 Xem đánh giá & điểm trung bình của sản phẩm

Quy tắc nghiệp vụ / Điều kiện:

- Hỗ trợ phân trang (mặc định 5/trang), lọc theo số sao; hiển thị điểm trung bình và tổng số lượt đánh giá của sản phẩm.

API liên quan: GET /api/reviews/product/{productId} | GET /api/reviews/product/{productId}/rating

3.7 Liên hệ, Banner & Chính sách

FR-CONTACT-01 Gửi liên hệ

Tác nhân: Khách, Customer

Quy tắc nghiệp vụ / Điều kiện:

- Biểu mẫu liên hệ công khai, không yêu cầu đăng nhập.
- Trạng thái khởi tạo của mỗi liên hệ là NEW.

API liên quan: POST /api/contacts

FR-BANNER-01 Xem banner trang chủ

Quy tắc nghiệp vụ / Điều kiện:

- Chỉ trả về các banner đang ở trạng thái hoạt động (active).
- Giao diện hiển thị dạng carousel tự động chuyển sau mỗi 5 giây, hỗ trợ thao tác thủ công (nút trước/sau, chấm điều hướng).
- Nếu chưa có banner nào, hiển thị ảnh nền mặc định (fallback) thay vì để trống.

API liên quan: GET /api/banners

FR-POLICY-01 Xem chính sách

Quy tắc nghiệp vụ / Điều kiện:

- 4 loại chính sách: vận chuyển (SHIPPING), đổi trả (RETURN), bảo hành (WARRANTY), điều khoản (TERMS).
- Chỉ hiển thị các chính sách đang ở trạng thái hoạt động.

API liên quan: GET /api/policies | GET /api/policies/{type}

3.8 Tư vấn sản phẩm bằng AI

FR-AI-01 Tư vấn sản phẩm bằng AI (Google Gemini)

Tác nhân: Khách, Customer

Quy tắc nghiệp vụ / Điều kiện:

- Người dùng mô tả nhu cầu/mong muốn bằng ngôn ngữ tự nhiên (hoặc chọn nhanh một gợi ý dựng sẵn); hệ thống gọi Google Gemini kèm ngữ cảnh sản phẩm thật của cửa hàng để trả lời tư vấn và gợi ý một số sản phẩm cụ thể kèm lý do.
- Không yêu cầu đăng nhập.
- Giao diện luôn hiển thị cảnh báo AI có thể chưa hoàn toàn chính xác và khuyến nghị tham khảo thêm ý kiến chuyên gia — cần kiểm thử để đảm bảo nội dung AI trả về không tư vấn sai lệch nghiêm trọng, vì đây là rủi ro phụ thuộc vào một mô hình AI bên ngoài, ngoài tầm kiểm soát trực tiếp của đội phát triển.

API liên quan: POST /api/recommendation

3.9 Quản trị hệ thống (Admin/Staff)

FR-ADMIN-PROD-01 Quản lý sản phẩm & biến thể

Tác nhân: Admin (toàn quyền), Staff (chỉ xem)

Quy tắc nghiệp vụ / Điều kiện:

- Staff có quyền xem danh sách/chi tiết sản phẩm, danh mục, hương vị, kích cỡ; mọi thao tác tạo/sửa/xoá/bật-tắt/khôi phục chỉ dành riêng cho Admin — cần kiểm thử xác nhận tài khoản Staff bị từ chối (403) khi gọi trực tiếp các API ghi dữ liệu này.
- Xoá sản phẩm là xoá mềm (đánh dấu đã xoá thay vì xoá vật lý khỏi cơ sở dữ liệu), có thể khôi phục lại; sản phẩm đã xoá mềm không hiển thị ở giao diện công khai.
- Mỗi sản phẩm có thể có nhiều biến thể (tổ hợp hương vị × kích cỡ), mỗi biến thể quản lý giá gốc/giá sale/% giảm/tồn kho/khối lượng riêng.

API liên quan: `/api/admin/products/**` (24 endpoint — xem Phụ lục A)

FR-ADMIN-ORD-01 Quản lý đơn hàng

Tác nhân: Admin, Staff

Quy tắc nghiệp vụ / Điều kiện:

- Xem/lọc danh sách đơn theo trạng thái, trạng thái thanh toán, tìm theo mã đơn, khoảng ngày; xem số liệu đơn theo ngày/tuần và top sản phẩm bán chạy phục vụ trang tổng quan.
- Cập nhật trạng thái đơn hàng phải tuân theo quy trình hợp lệ (không cho chuyển trạng thái tùy ý, ví dụ không thể chuyển thẳng từ PENDING sang DELIVERED); khi chuyển sang CANCELLED phải có lý do.
- Xử lý hoàn tiền cho đơn đã thanh toán online bị huỷ/hoàn trả, kèm ghi chú; trạng thái thanh toán chuyển sang REFUND_PENDING rồi REFUNDED.

API liên quan: `/api/admin/orders/**` (8 endpoint)

FR-ADMIN-PROMO-01 Quản lý khuyến mãi

Tác nhân: Chỉ Admin (Staff không có quyền truy cập — xác nhận trực tiếp từ chú thích trong mã nguồn AdminPromotionController)

Quy tắc nghiệp vụ / Điều kiện:

- Tạo/sửa/bật-tắt mã khuyến mãi (loại PERCENT/FIXED, phạm vi PUBLIC/PERSONAL, giá trị đơn tối thiểu, giới hạn lượt dùng tổng và theo từng người dùng, thời hạn hiệu lực).
- Xem lịch sử sử dụng của từng mã khuyến mãi.

API liên quan: `/api/admin/promotions/**` (6 endpoint)

FR-ADMIN-USER-01 Quản lý người dùng

Tác nhân: Chỉ Admin

Quy tắc nghiệp vụ / Điều kiện:

- Xem danh sách người dùng (lọc theo từ khoá/vai trò/trạng thái hoạt động), khoá/mở khoá tài khoản, thay đổi vai trò (CUSTOMER/STAFF/ADMIN).
- Cần có cơ chế tự bảo vệ để Admin không thể tự khoá tài khoản hoặc tự hạ quyền chính mình dẫn đến mất quyền truy cập hệ thống — cần thiết kế test case xác nhận hành vi này.

API liên quan: `GET /api/admin/users` | `PATCH /api/admin/users/{id}/toggle-active` | `PATCH /api/admin/users/{id}/role`

FR-ADMIN-USER-02 Tạo mã khuyến mãi cá nhân cho khách hàng cụ thể

Tác nhân: Chỉ Admin

Quy tắc nghiệp vụ / Điều kiện:

- Tạo khuyến mãi phạm vi PERSONAL gắn với một khách hàng cụ thể, phục vụ chăm sóc khách hàng riêng lẻ.

API liên quan: POST /api/admin/users/{userId}/personal-promos

FR-ADMIN-REVIEW-01 Kiểm duyệt đánh giá

Tác nhân: Admin, Staff

Quy tắc nghiệp vụ / Điều kiện:

- Xem/loại theo trạng thái duyệt và số sao; ẩn/hiện lại đánh giá; xoá hẳn đánh giá vi phạm; phản hồi đánh giá thay mặt cửa hàng (có thể xoá phản hồi bằng cách gửi nội dung rỗng).

API liên quan: /api/admin/reviews/** (4 endpoint)

FR-ADMIN-CONTACT-01 Xử lý liên hệ khách hàng

Tác nhân: Admin, Staff

Quy tắc nghiệp vụ / Điều kiện:

- Xem/loại theo trạng thái (NEW/IN_PROGRESS/RESOLVED), xem thống kê số lượng theo trạng thái, cập nhật trạng thái xử lý, trả lời liên hệ (hệ thống tự động gửi email phản hồi cho khách hàng).

API liên quan: /api/admin/contacts/** (4 endpoint)

FR-ADMIN-BANNER-01 Quản lý banner trang chủ

Tác nhân: Chỉ Admin

Quy tắc nghiệp vụ / Điều kiện:

- Tạo/sửa/xoá/bật-tắt banner hiển thị ở trang chủ.

API liên quan: /api/admin/banners/** (5 endpoint)

FR-ADMIN-POLICY-01 Quản lý nội dung chính sách

Tác nhân: Chỉ Admin

Quy tắc nghiệp vụ / Điều kiện:

- Mỗi loại chính sách (SHIPPING/RETURN/WARRANTY/TERMS) chỉ có đúng một bản ghi (ràng buộc duy nhất theo loại) — chức năng "tạo mới" thực chất chỉ dùng khi khởi tạo dữ liệu lần đầu; vận hành bình thường là cập nhật nội dung và bật/tắt hiển thị.

API liên quan: /api/admin/policies/** (5 endpoint)

FR-ADMIN-TAG-01 Quản lý nhãn sản phẩm (tag)

Tạo/xoá/bật-tắt nhãn dùng để gắn cho sản phẩm (Bestseller/Organic/New/Sale...); tên nhãn được lưu dạng chữ thường, không cho phép trùng tên.

Quy tắc nghiệp vụ / Điều kiện:

- ⚠ PHÁT HIỆN QUAN TRỌNG (đã xác minh trực tiếp trong mã nguồn): AdminTagController KHÔNG có bất kỳ ràng buộc phân quyền (@PreAuthorize) nào — khác với tất cả các controller /api/admin/**

còn lại đều yêu cầu vai trò ADMIN hoặc STAFF. Điều này đồng nghĩa mọi người dùng đã đăng nhập, kể cả vai trò CUSTOMER, có khả năng gọi trực tiếp được các API quản trị nhãn sản phẩm.

- Đây là một phát hiện bảo mật cụ thể cần được nhóm xác nhận lại bằng kiểm thử thực tế (ví dụ: dùng token của tài khoản CUSTOMER gọi thử POST /api/admin/tags) và đưa vào báo cáo lỗi chính thức với mức độ ưu tiên cao nếu xác nhận đúng.

API liên quan: /api/admin/tags/** (4 endpoint)

FR-ADMIN-DASH-01 Trang tổng quan (Dashboard)

Tác nhân: Admin, Staff

Quy tắc nghiệp vụ / Điều kiện:

- Hiển thị 6 chỉ số nhanh: doanh thu hôm nay, doanh thu tuần này, doanh thu tháng này, số đơn hàng mới, số biến thể sắp hết hàng, số đánh giá chờ duyệt.
- Biểu đồ doanh thu theo 3 khoảng thời gian: 7 ngày, 30 ngày, 12 tháng.

API liên quan: GET /api/admin/dashboard/summary | GET /api/admin/dashboard/revenue-chart

4. Yêu cầu phi chức năng

Các yêu cầu dưới đây kết hợp giữa quan sát thực tế từ mã nguồn (đánh dấu rõ trong nội dung) và khuyến nghị kiểm thử của nhóm, phân loại theo các nhóm chất lượng phổ biến trong kiểm thử phần mềm.

4.1 Tính khả dụng (Usability)

- Giao diện hoàn toàn bằng tiếng Việt, responsive trên di động/máy tính bảng/máy tính để bàn (Tailwind CSS).
- Có trạng thái tải (preloader, skeleton loading) khi chờ dữ liệu ở trang chủ và trang danh sách sản phẩm để tránh cảm giác treo trang.
- Thông báo lỗi bằng tiếng Việt rõ ràng cho từng hành động (toast/thông báo inline) — cần kiểm thử tính nhất quán của các thông báo lỗi giữa các module.
- Có bước xác nhận trước các hành động không thể hoàn tác (ví dụ: hộp thoại xác nhận "Xóa tài khoản vĩnh viễn?").

4.2 Bảo mật (Security)

- Xác thực bằng JWT: access token hết hạn sau 1 giờ, refresh token hết hạn sau 7 ngày (theo cấu hình application.yml).
- Access token bị thu hồi khi đăng xuất phải được đưa vào danh sách chặn (blacklist) trên Redis và bị từ chối ngay từ request kế tiếp, dù token chưa hết hạn theo thời gian.
- Giới hạn số lần đăng nhập sai bằng mật khẩu, bắt buộc xác minh reCAPTCHA sau khi vượt ngưỡng cho phép.
- Giới hạn gửi OTP tối đa 10 lần/ngày/số điện thoại, khoá xác thực 15 phút sau 3 lần nhập sai mã OTP.
- Mọi endpoint thuộc nhóm /api/admin/** phải được bảo vệ đúng theo Ma trận phân quyền ở Mục 5. [⚠](#) Ghi nhận qua khảo sát mã nguồn: AdminTagController hiện KHÔNG có ràng buộc phân quyền — đây là điểm cần kiểm thử bảo mật ưu tiên cao (xem chi tiết ở FR-ADMIN-TAG-01).
- Không được lưu các thông tin bí mật (mật khẩu ứng dụng email, khoá ký JWT, khoá reCAPTCHA, token GHN, khoá bí mật VNPay, khoá SePay...) dưới dạng văn bản thuần trong mã nguồn commit lên hệ thống quản lý phiên bản công khai. Ghi nhận phát hiện: tệp cấu hình môi trường cục bộ của backend hiện đang chứa các giá trị bí mật thật và được commit công khai — mức độ Nghiêm trọng (Critical), đã được ghi nhận trong Tài liệu kế hoạch kiểm thử của nhóm, cần được chủ dự án xoay vòng (rotate) toàn bộ khoá/mật khẩu liên quan trước khi đưa hệ thống ra môi trường thật.
- CORS chỉ cho phép các nguồn gốc (origin) cụ thể đã khai báo, ngoại trừ nhóm /api/webhooks/** được mở riêng cho bên thứ ba gọi vào và xác thực bằng khoá API riêng thay vì JWT.
- Webhook SePay phải xác thực đúng khoá API trong header Authorization trước khi xử lý; theo thiết kế luôn trả về HTTP 200 để tránh bị gọi lại liên tục — cần giám sát log riêng cho các lỗi xử lý nội bộ vì sẽ không có cơ chế thử lại tự động.
- Giao dịch VNPay phải được xác minh chữ ký HMAC-SHA512 bằng khoá bí mật cấu hình riêng theo môi trường trước khi cập nhật trạng thái thanh toán.
- Mật khẩu người dùng phải được băm (hash) trước khi lưu vào cơ sở dữ liệu — cần kiểm thử xác nhận không có trường hợp lưu mật khẩu dạng văn bản thuần.
- API tạo URL thanh toán VNPay nhận trực tiếp orderId từ phía client và không có ràng buộc phân quyền vai trò cụ thể ở tầng controller — cần kiểm thử xác nhận tầng service có kiểm tra đúng đơn hàng đó thuộc về người dùng đang gọi API hay không, tránh rủi ro một người dùng tạo được URL thanh toán cho đơn hàng của người khác (IDOR).

4.3 Hiệu năng (Performance)

- Danh sách sản phẩm hỗ trợ phân trang (12 sản phẩm/trang) kết hợp cuộn vô hạn (infinite scroll); các thay đổi bộ lọc được debounce 300ms để giảm số lượng lệnh gọi API không cần thiết.
- Các dữ liệu tần suất truy cập cao và có tính tạm thời (đếm OTP, đếm lần đăng nhập sai, danh sách token bị thu hồi) được lưu trên Redis thay vì cơ sở dữ liệu chính để đảm bảo tốc độ truy xuất.
- Backend triển khai trên nền tảng Railway có hiện tượng "ngủ" (cold start) khi không có truy cập trong một khoảng thời gian; giao diện có cơ chế tự động thử lại sau khoảng 12 giây nếu request đầu tiên gặp lỗi mạng — nhóm nên kiểm thử thời gian phản hồi ở trạng thái "ngủ" (có thể lên tới khoảng 15 giây cho lần gọi đầu tiên) như một kịch bản hiệu năng riêng, không tính là lỗi.
- Các tác vụ nền (tự động huỷ đơn quá hạn, tự động cập nhật trạng thái giao hàng) chạy theo lịch cố định, không nên ảnh hưởng đến thời gian phản hồi của các request thông thường trong cùng thời điểm — nên kiểm thử hiệu năng khi tác vụ nền chạy đồng thời với lưu lượng truy cập thật.

4.4 Độ tin cậy (Reliability)

- Đơn hàng chuyển trạng thái theo một quy trình xác định (PENDING → CONFIRMED → SHIPPING → DELIVERED, hoặc → CANCELLED ở các bước phù hợp), hệ thống không được cho phép chuyển sang trạng thái không hợp lệ theo quy trình.
- Thanh toán chuyển khoản (MoMo/Chuyển khoản ngân hàng) phải được xác nhận tự động qua webhook, có đối chiếu đúng số tiền và nội dung chuyển khoản (mã đơn hàng), tránh xác nhận nhầm đơn hàng.
- Đơn hàng thanh toán online quá hạn thanh toán phải được tự động huỷ để giải phóng tồn kho và lượt dùng khuyến mãi kịp thời, tránh giữ tài nguyên không cần thiết.

4.5 Khả năng tương thích (Compatibility)

- Giao diện phải hoạt động tốt trên các trình duyệt phổ biến hiện đại (Chrome, Edge, Firefox, Safari) ở cả phiên bản desktop và di động.
- Môi trường phát triển/kiểm thử yêu cầu: Node.js ≥ 18, JDK 21, MySQL ≥ 8.0, Redis, Maven ≥ 3.8. Ghi chú: tệp README của dự án hiện ghi "Java >= 17" nhưng cấu hình build (pom.xml) khai báo phiên bản Java 21 — nhóm nên thống nhất dùng JDK 21 để tránh lỗi biên dịch, đồng thời đề xuất cập nhật lại README cho khớp thực tế.

4.6 Khả năng bảo trì (Maintainability)

- Backend được tổ chức theo kiến trúc phân tầng rõ ràng của Spring Boot: controller → service (interface + implementation) → repository → entity/dto, thuận lợi cho việc viết unit test theo từng tầng.
- Hệ thống chưa tích hợp công cụ sinh tài liệu API tự động (không có springdoc/Swagger trong cấu hình build) — nhóm cần tự xây dựng và duy trì bộ Postman collection để thay thế trong quá trình kiểm thử API (xem mục 3.5 của Tài liệu kế hoạch kiểm thử).

4.7 Yêu cầu pháp lý / Dữ liệu

- Thông tin thanh toán (các khoá bí mật của VNPay, SePay...) và dữ liệu cá nhân người dùng (số điện thoại, địa chỉ) cần được bảo vệ phù hợp tinh thần các quy định về bảo vệ dữ liệu cá nhân hiện hành. Do đây là đề án môn học, phạm vi tài liệu chỉ dừng ở mức khuyến nghị kiểm thử, không đánh giá tuân thủ pháp lý đầy đủ.

5. Ma trận phân quyền theo vai trò

Bảng dưới đây tổng hợp quyền truy cập theo từng nhóm chức năng, xác nhận trực tiếp từ ràng buộc @PreAuthorize (hoặc việc không có ràng buộc nào) trên từng controller trong mã nguồn backend. Ký hiệu: ✓ = được phép, ✗ = không được phép.

Nhóm chức năng	Khách	Customer	Staff	Admin
Đăng ký / đăng nhập (OTP, mật khẩu, Google)	✓	✓	✓	✓
Xem sản phẩm, banner, chính sách, AI tư vấn, gửi liên hệ	✓	✓	✓	✓
Giỏ hàng, đặt hàng, thanh toán, hủy/xác nhận đơn của chính mình	✗	✓	✗*	✗*
Viết đánh giá sản phẩm	✗	✓	✗	✗
Quản lý hồ sơ & địa chỉ cá nhân	✗	✓	✓ (của chính mình)	✓ (của chính mình)
Xem đơn hàng (toàn hệ thống), cập nhật trạng thái, hoàn tiền	✗	✗	✓	✓
Xem/kiểm duyệt đánh giá, xử lý liên hệ, dashboard	✗	✗	✓	✓
Xem sản phẩm/danh mục/hương vị/kích cỡ (khu vực quản trị)	✗	✗	✓ (chỉ xem)	✓
Tạo/sửa/xoá sản phẩm, biến thể, danh mục, hương vị, kích cỡ	✗	✗	✗	✓
Quản lý khuyến mãi (toàn bộ)	✗	✗	✗	✓
Quản lý người dùng, đổi vai trò, khoá tài khoản	✗	✗	✗	✓
Quản lý banner, chính sách	✗	✗	✗	✓
Quản lý nhãn sản phẩm (tag)	✗ (theo thiết kế dự kiến)	✗ (theo thiết kế dự kiến)	✗ (theo thiết kế dự kiến)	✓ — nhưng thực tế mã nguồn KHÔNG kiểm tra vai trò, xem cảnh báo FR-ADMIN-TAG-01

* Staff và Admin không có tài khoản khách hàng gắn liền với vai trò CUSTOMER trong dữ liệu khảo sát; module giỏ hàng/đặt hàng yêu cầu cụ thể vai trò CUSTOMER (@PreAuthorize("hasRole('CUSTOMER')")) nên một tài khoản Staff/Admin thuần túy sẽ không mua hàng được trừ khi hệ thống cho phép gán nhiều vai trò — cần kiểm thử xác nhận hành vi khi một tài khoản không phải CUSTOMER thử truy cập các API này.

6. Phụ lục

Phụ lục A — Danh sách API đầy đủ theo controller

Tổng cộng 26 controller, 124 endpoint (đếm trực tiếp từ mã nguồn backend). Chi tiết từng endpoint (đường dẫn, phương thức HTTP, vai trò yêu cầu) được trình bày đầy đủ trong Tài liệu mô tả hệ thống (Mục "Kiến trúc Backend").

Controller	Base path	Số endpoint	Vai trò yêu cầu
AddressController	/api/users/me/addresses	6	CUSTOMER (ngầm định qua xác thực JWT)
AdminBannerController	/api/admin/banners	5	ADMIN
AdminContactController	/api/admin/contacts	4	STAFF, ADMIN
AdminOrderController	/api/admin/orders	8	STAFF, ADMIN
AdminPolicyController	/api/admin/policies	5	ADMIN
AdminProductController	/api/admin/products	24	STAFF (chỉ xem), ADMIN (toàn quyền)
AdminPromotionController	/api/admin/promotions	6	ADMIN
AdminReviewController	/api/admin/reviews	4	STAFF, ADMIN
AdminTagController	/api/admin/tags	4	⚠ Không có ràng buộc (xem FR-ADMIN-TAG-01)
AdminUserController	/api/admin/users	4	ADMIN
AuthController	/api/auth	11	Công khai (một số endpoint yêu cầu JWT: change-password)
BannerController	/api/banners	1	Công khai
CartController	/api/cart	5	CUSTOMER
ContactController	/api/contacts	1	Công khai
DashboardController	/api/admin/dashboard	2	STAFF, ADMIN
OrderController	/api/orders	8	CUSTOMER
PaymentController	/api/payment	3	Yêu cầu JWT hợp lệ (create-url); IPN/Return công khai cho VNPay gọi vào
PolicyController	/api/policies	2	Công khai
ProductController	/api/products	7	Công khai
PromotionController	/api/promos	1	CUSTOMER
RecommendationController	/api/recommendation	1	Công khai
ReviewController	/api/reviews	4	CUSTOMER (tạo/kiểm tra), Công khai (xem)
ShippingController	/api/shipping	3	Công khai
ShippingFeeController	/api/orders/shipping-fee	1	Yêu cầu JWT hợp lệ

Controller	Base path	Số endpoint	Vai trò yêu cầu
UserController	/api/users	3	Yêu cầu JWT hợp lệ
WebhookController	/api/webhooks	1	Khoá API riêng (không dùng JWT)

Phụ lục B — Danh mục 23 bảng dữ liệu

Chi tiết cấu trúc từng bảng (cột, kiểu dữ liệu, khoá chính/ngoại, ràng buộc) được trình bày trong Tài liệu mô tả hệ thống (Mục "Mô hình dữ liệu"). Danh sách dưới đây nhóm 23 bảng theo miền nghiệp vụ:

Nhóm	Bảng
Xác thực	users, otp_verifications, social_accounts
Địa chỉ	addresses
Sản phẩm	categories, flavors, sizes, products, product_images, product_tags, tag_definitions, product_variants
Giỏ hàng	carts, cart_items
Đơn hàng	orders, order_items, payments
Khuyến mãi	promotions, promotion_usages
Đánh giá	reviews
Khác	contacts, shipping_policies, banners

Phụ lục C — Ghi chú về phương pháp biên soạn

- Tài liệu được biên soạn bằng cách khảo sát trực tiếp: schema.sql (toàn bộ 23 bảng), 23 entity JPA tương ứng, toàn bộ 26 controller, khoảng 75 DTO request/response, các lớp service triển khai nghiệp vụ chính, cấu hình bảo mật/CORS/Redis, và mã nguồn frontend (định tuyến, state management, lớp gọi API, các trang giao dịch chính) của dự án Green Juice Hub tại thời điểm 20/08/2026.
- Các câu có đánh dấu "cần kiểm thử xác nhận" hoặc "△" là các điểm mã nguồn thể hiện chưa rõ ràng, có khả năng chưa nhất quán, hoặc là phát hiện đáng chú ý — nhóm nên ưu tiên xác nhận lại bằng kiểm thử thực tế trước khi kết luận là lỗi chính thức.
- Tài liệu này nên được xem là "đường cơ sở sống" (living baseline) — cập nhật lại khi nhóm phát hiện sai khác giữa tài liệu và hành vi thực tế trong quá trình kiểm thử.